

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

Supervisor:
Dr. Bui Van Hieu
Dr. Dang Van Hieu

Abstract

In the era of digital transformation and burgeoning network traffic, modern Security Operations Centres (SOCs) face severe alert fatigue, as the volume of telemetry collected from monitoring systems far exceeds manual analysis capacity. Traditional defense tools exhibit clear limitations: static signature rules generate high false-positive rates due to a lack of context interpretation, while pre-programmed SOAR playbooks execute reliably only on anticipated scenarios. Transitioning to Large Language Models (LLMs) enables automated contextual reasoning in natural language; however, operational adoption remains constrained by latency bottlenecks, high computational costs, general adversarial risks (typically log-substrate prompt injections), and AI hallucinations. To address these challenges, this thesis proposes SENTINEL, a cognitive two-tier security architecture operating fully air-gapped, designed on the principle of placing cheap decisions before expensive ones. Tier 1 combines a Welford $\mathcal{O}(1)$ statistical filter and a LightGBM Machine Learning Gate to settle stream noise at wire-speed, offloading 90.6% to 97.5% of telemetry without invoking LLM resources and reducing median end-to-end latency from 17,174.7 ms to 0.88 ms. Tier 2 executes a LangGraph agentic engine integrated with a Dual-RAG hybrid retrieval mechanism (FAISS + BM25 RRF $k = 60$) over 433 MITRE ATT&CK technique entries, while the AWAIT_HITL deferral channel reduces analyst workload by 84.24% while retaining a 95.0% recall on genuine threats. Finally, Delimited Nonce Encapsulation provides structural guarantees to robustly withstand 678 adversarial attack samples (including log-substrate prompt injections), and HMAC-SHA256 signature chaining ensures effective tamper-detection for forensic audit trails.

Acknowledgments

The completion of this Master's thesis and the fulfillment of the requirements for the Master of Software Engineering degree would not have been possible without the invaluable support, guidance, and encouragement from my advisors, faculty members, colleagues, and family.

First and foremost, I express my deepest gratitude and utmost respect to my academic supervisors, Dr. Bùi Văn Hiệu and Dr. Đặng Văn Hiếu. Through their profound scholarly expertise, precise strategic guidance, and rigorous research standards, my supervisors patiently mentored my critical thinking and inspired my research methodology throughout this thesis journey. Their sharp professional insights have not only refined this work but also provided an invaluable intellectual foundation for my future research in cybersecurity and artificial intelligence.

I respectfully extend my sincere appreciation to the Board of Management and leadership of the FSB Institute of Management & Technology, as well as the faculty of FPT University, for imparting solid theoretical and practical knowledge in a professional research environment. I also sincerely thank the leadership and colleagues at the C12 Department, National Data Center. Their trust, flexible accommodations, and rich practical domain expertise provided deep operational insights that substantially contributed to the design, experimentation, and validation of the SENTINEL system.

Finally, I dedicate my heartfelt gratitude to my beloved family, especially my caring wife and young child. Their silent sacrifices, immense patience, and unwavering encouragement throughout late-night experimental sessions served as my strongest pillar of support. Despite my utmost efforts, limitations may remain; I welcome constructive feedback and guidance from the thesis evaluation committee and esteemed colleagues.

Contents

Abstract	i
Acknowledgments	ii
List of Figures	iv
List of Tables	iv
List of Abbreviations	vi
1 Introduction	1
1.1 Background and Motivation	1
1.2 Objectives, Research Questions, Scope and Contributions	2
1.3 Structure of the Thesis	3
2 Theoretical Background and Literature Review	4
2.1 Current SOC Operations and the Cognitive Bottleneck	4
2.2 Deterministic Rules, Online Statistics, and Tier 1 Machine Learning	5
2.3 Local Large Language Models and Tier 2 Agentic Intelligence	5
2.4 Adversarial AI Security and Log Audit Cryptography	6
2.5 Overview of Related Research and Research Gaps	7
3 System Design and Technical Implementation	9
3.1 Research Methodology	9
3.2 SENTINEL Architecture Overview and SOC Stack Integration	10
3.3 Tier 1: Wire-speed Filter and Machine Learning Gate	11
3.4 Tier 2: LangGraph Cognitive Agent and Threat Memory	13
3.5 Dual-RAG Hybrid Knowledge Retrieval	14
3.6 Adversarial AI Security and Cryptographic Audit Sealing	15
4 Experiments and Evaluation	17
4.1 RQ1 — Offloading and Filtration Economics	17
4.2 RQ2 — AI Security Guardrails and Forensic Integrity	21
4.3 RQ3 — Stateful Reasoning and Attribution	25
5 Conclusion	31
References	1

List of Figures

Figure 1.	SENTINEL architecture overview. (Source: Author)	11
Figure 2.	Tier 1 detail diagram. (Source: Author)	12
Figure 3.	Tier 2 agent state-graph. (Source: Author)	14
Figure 4.	Dual-RAG hybrid retrieval and output evidence-anchoring guardrail. (Source: Author)	15
Figure 5.	Input Nonce encapsulation and output HMAC audit chaining. (Source: Author)	16
Figure 6.	Offload composition on the two streams; the tier carrying the load inverts with the attack base rate. Generated from offload_vs_baserate_{stream,demo}.json. (Source: Author)	18
Figure 7.	Cumulative latency distribution over the same 500 events. The advantage is concentrated in the body of the distribution; in the tail the two-tier system is slower. Generated from latency_benchmark.json. (Source: Author)	20
Figure 8.	Static pre-filter, block rate by provenance beside the false-flag rate on benign logs. Generated from robustness_results.json and adversarial_negative_results.json. (Source: Author) . . .	23
Figure 9.	Attribution by technique against the retrieval ceiling. Where the light bar is high and the dark bars are zero, the mapper is at fault; where the light bar is zero, the knowledge base is. Generated from the three RQ3 result files. (Source: Author)	26
Figure 10.	Alert triage at Tier 2. The confirmation channel is almost pure false positives; the deferral channel concentrates the threats. Generated from tier2_decision_results.json. (Source: Author)	28
Figure 11.	Left: action accuracy by configuration with 95% confi- dence intervals; A and F share a denominator, B–E do not. Right: the four judge axes, with context precision the weak one. Generated from ablation_action_scores.json and reasoning_eval_results.json. (Source: Author)	29

List of Tables

Table 1.	Comparative analysis between SENTINEL and existing security defense solutions	8
Table 2.	Per-Tier Offload Rate on Two Streams with Different Base Rates . .	18
Table 3.	Throughput of Control Configurations on an Identical 150-Event Stratified Subset	20
Table 4.	Guardrail Layers, Measurement Denominators, and Results	22
Table 5.	Attribution by technique on the 500-sample payload slice, with the retrieval ceiling for the same queries. Attribution is scored on all 250 labelled samples; retrieval on the 243 of them that Tier 1 escalated, and at parent-technique granularity, so the two denominators differ and are not interchangeable.	25
Table 6.	Ablation scored on the final action, with the 50 author-composed samples excluded. Configurations A and F are scored on all 1,700 remaining samples; B–E on a separate 300-sample slice and therefore not directly comparable with A and F. Generated from <code>ablation_action_scores.json</code>	29

List of Abbreviations

Abbreviation	Full Description
AI	Artificial Intelligence
AUC-ROC	Area Under the Receiver Operating Characteristic Curve
CTI	Cyber Threat Intelligence
DSRM	Design Science Research Methodology
ECDF	Empirical Cumulative Distribution Function
FAISS	Facebook AI Similarity Search
FNR	False Negative Rate
FPR	False Positive Rate
FSM	Finite State Machine
GGUF	GPT-Generated Unified Format
HITL	Human-in-the-Loop
HMAC	Hash-based Message Authentication Code
IDS / IPS	Intrusion Detection / Prevention System
KV	Key-Value (LLM KV-Cache Mechanism)
LLM	Large Language Model
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge
NIST	National Institute of Standards and Technology
RAG	Retrieval-Augmented Generation
RRF	Reciprocal Rank Fusion
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center
TPR	True Positive Rate
WAF	Web Application Firewall

Chapter 1

Introduction

This chapter states the research context and central problem of SENTINEL, a cognitive two-tier architecture automating threat detection and incident response in Security Operations Centres (SOCs), together with the objectives, research questions, research object, scope, and scientific contributions of the thesis.

1.1 Background and Motivation

In the era of digital transformation and burgeoning network traffic, modern Security Operations Centres (SOCs) face severe alert fatigue, as daily telemetry ingestion reaching millions of log events far exceeds manual analysis capacity [1]. To avoid missing intrusions, monitoring sensors are configured toward high sensitivity, causing the vast majority of queued alerts to represent benign activity that does not require direct analyst intervention [2, 3]. Consequently, the operational bottleneck of a modern SOC lies not in data ingestion, but in allocating the scarce attention of human analysts.

Three traditional defense layers—firewalls with static signature intrusion detection (IDS/IPS), SIEM platforms correlating telemetry via rule sets, and pre-programmed SOAR playbooks—exhibit clear limitations: they lack dynamic contextual reasoning and execute reliably only on anticipated scenarios [4]. Unresolved events accumulate in manual queues, forcing analysts to perform time-consuming tasks: extracting raw logs, reconstructing source IP behaviors, cross-referencing asset inventories, and mapping attack techniques. This sequential process creates both a time bottleneck causing backlog accumulation and a context bottleneck as deciding evidence remains scattered across unstructured log records.

Transitioning to Large Language Models (LLMs) enables automated contextual reasoning in natural language; however, operational adoption is constrained by three major challenges: (1) multi-second LLM inference latency conflicts with wire-speed data streams [5]; (2) the AI reasoning layer itself becomes vulnerable to log-substrate prompt injection attacks [6], mandating tamper-sealed audit trails; and (3) internal security telemetry must execute fully local (air-gapped) on finite hardware due to strict data privacy requirements [7]. The 4-to-5 order-of-magnitude computational cost gap between traditional statistical rules ($\ll 1$ ms) and LLMs (seconds) necessitates designing SENTINEL on the principle of *placing cheap decisions before expensive ones*: offloading stream noise at wire-speed and invoking LLM reasoning only for events that truly warrant complex analysis.

1.2 Objectives, Research Questions, Scope and Contributions

To address the central problem, the general objective of this thesis is structured into three distinct yet mutually supportive research tracks, mapped to three research questions (RQs) and primary scientific contributions. The complete architectural design and quantitative experimental evaluations are demonstrated in Chapter 4.

The first track focuses on telemetry tiering: designing a stateless dual-stage filtration pipeline at wire-speed to offload telemetry at the cheap computing tier. RQ1 is formulated as follows: *How can a multi-tiered architecture be designed to autonomously offload security telemetry at wire-speed, thereby addressing the latency bottlenecks and resource consumption inherent in Large Language Models?* The corresponding contribution quantifies the principle of placing cheap decisions before expensive ones and empirically demonstrates the relationship between the offload rate and the attack base rate.

The second track focuses on reasoning security and audit integrity: protecting the language model via structural guardrails and sealing forensic records. RQ2 is formulated as follows: *What methodologies and security mechanisms can effectively withstand adversarial risks to protect the AI's reasoning flow, while ensuring the integrity and tamper-evidence of forensic audit trails?* The corresponding contribution introduces Delimited Nonce Encap-

sulation, providing deterministic structural guarantees independent of probabilistic classifiers [8].

The third track focuses on cognitive reasoning and incident triage: building a stateful agentic engine integrated with domain security knowledge. RQ3 is formulated as follows: *How can stateful reasoning capabilities and domain-specific knowledge retrieval be integrated into an AI Agent to automate intrusion analysis, attribute attack techniques, and generate transparent forensic reports?* The corresponding contribution provides a stateful LangGraph agent operating over a STIX-aligned MITRE ATT&CK knowledge base, coupled with a RAG-anchoring guardrail to mitigate hallucinations.

The scope and methodology are bounded as follows: the research domain focuses on automated telemetry analysis, alert triage, and AI reasoning security in SOCs. The research object encompasses high-speed telemetry tiering algorithms (application signature Rule-based, Welford $\mathcal{O}(1)$ statistics coupled with LightGBM Machine Learning Gate), deterministic adversarial defense (Nonce Encapsulation and HMAC-SHA256), and stateful reasoning agents (LangGraph FSM) with hybrid retrieval (Dual-RAG FAISS + BM25 RRF). Experimentally, SENTINEL is evaluated on two benchmark datasets, CSE-CIC-IDS2018 [10] and CSIC 2010 [11], alongside 823 adversarial attack samples (AdvBench [13], deepset [14], jackhhao [15]) deployed on an air-gapped workstation.

1.3 Structure of the Thesis

Chapter 2 systematizes theoretical foundations and surveys related work to establish the research gap. Chapter 3 presents the research methodology and technical design of SENTINEL. Chapter 4 presents quantitative evaluation results organized strictly according to the three research questions above. Chapter 5 concludes with a summary of contributions, discussion of limitations, and directions for future work.

Chapter 2

Theoretical Background and Literature Review

This chapter presents the foundational theoretical principles of this thesis, covering: current SOC operations and the cognitive bottleneck, deterministic rules, online statistics, and Tier 1 machine learning, local large language models and Tier 2 agentic intelligence, adversarial AI security and log audit cryptography, and an overview of related work to delineate the research gap addressed by SENTINEL.

2.1 Current SOC Operations and the Cognitive Bottleneck

This section analyzes the core architectural causes of the alert overload described in Chapter 1. In a standard SOC model, monitoring relies on aggregating raw telemetry from sensors such as Next-Generation Firewalls (NGFW), Intrusion Detection Systems (IDS/IPS), and Endpoint Detection and Response (EDR) into a centralized SIEM platform [1], at volumes far exceeding manual human analysis capacity [16]. The primary architectural bottleneck stems from the operational nature of these sensors: they render decisions predominantly via static signatures or deterministic rule sets. Because the cost of missing an intrusion is severe, operators are forced to lower detection thresholds. However, lowering thresholds in signature-based systems exponentially increases false positive volume in analysis queues without enhancing contextual understanding [2, 3].

At the higher operational layer, Security Orchestration, Automation, and Response (SOAR) platforms attempt to reduce manual workload by executing pre-programmed response playbooks [4]. Nevertheless, SOAR is strictly constrained by playbook rigidity: a playbook triggers successfully only when alert parameters precisely match anticipated scenarios.

For complex multi-stage attack chains, novel behavioral anomalies, or unstructured evidence scattered across multiple records, SIEM, IDS/IPS, and SOAR layers collectively fail to form contextual judgments. Consequently, all unresolved cases escalate to manual analysis queues, transforming human analysts into the sole cognitive bottleneck of the entire security lifecycle.

2.2 Deterministic Rules, Online Statistics, and Tier 1 Machine Learning

Operating at wire-speed imposes strict algorithmic constraints on Tier 1: processing mechanisms must achieve constant $\mathcal{O}(1)$ time and memory complexity. First, a rule-based defense layer uses static set-matching and service-port lookups to instantly eliminate coarse anomalies without consuming computational resources. Next, baseline tracking applies Welford’s incremental recurrence formula [17] to continuously update the running mean μ_k and sum of squared deviations S_k per observation, computing standard deviation $\sigma_k = \sqrt{S_k/(k-1)}$ and dynamic Z-scores without storing raw historical telemetry:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

Finally, Gradient Boosted Decision Tree (GBDT) machine learning models—exemplified by LightGBM [18]—provide rapid classification of multi-dimensional telemetry patterns. Combining deterministic rule filtering, Z-score statistical normalization, and machine learning classification creates a high-speed multi-stage defense line, ensuring high-throughput offloading while maintaining robustness against adversarial telemetry variants.

2.3 Local Large Language Models and Tier 2 Agentic Intelligence

Executing the reasoning tier entirely on-premise is mandatory to guarantee internal security data sovereignty, while imposing strict GPU memory boundaries. Quantization

compresses weight representations onto a coarser integer grid, trading a minor amount of numerical fidelity for significant memory reduction [19]. Under GGUF Q4_K_M, the security-specialized Foundation-Sec-8B-Instruct model [20, 21] occupies approximately 7–8 GB VRAM, preserving sufficient headroom for context buffers and retrieval indices on a local GPU.

The reasoning tier orchestrates analysis flows via a LangGraph state graph [22]. To mitigate hallucinations and ground decisions in verifiable evidence [23], the system combines hybrid retrieval across dense vector search (FAISS) [24] and sparse keyword matching (BM25) [25]. Retrieved candidates are fused by rank position using Reciprocal Rank Fusion (RRF) [26]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

enabling transparent cross-referencing of log telemetry against MITRE ATT&CK technique codes [35] and NIST SP 800-61r2 incident handling guidelines [36].

2.4 Adversarial AI Security and Log Audit Cryptography

Integrating Large Language Models into security operations introduces log-substrate prompt injection risks [6, 8]. Because raw log content is adversary-controlled, content-matching filters or probabilistic keyword detectors remain vulnerable to novel adversarial variants [27]. This theoretical foundation necessitates protecting the reasoning tier via deterministic structural isolation (Delimited Nonce Encapsulation), establishing an absolute boundary between control instructions and untrusted telemetry.

Regarding forensic audit integrity, evidence records are sealed in sequence using HMAC-SHA256 signature chaining [28] under a local secret key. Theoretical boundaries must be precisely stated: symmetric HMAC encryption guarantees tamper-evidence and modification detection, but does not provide non-repudiation, which requires asymmetric digital signature infrastructure.

2.5 Overview of Related Research and Research Gaps

AI-driven security operations research has evolved across three main architectural paradigms, as surveyed by Zhang et al. [29].

The first group, traditional enterprise defenses, comprises SIEM platforms such as IBM QRadar and SOAR tools like Palo Alto Cortex XSOAR [1, 4]. These systems are complemented by online log parsers like Drain [34], which compress syntax but cannot analyze behavioral context. Operators bear the burden of this rigidity: in interviews with SOC personnel, AlAhmadi et al. [3] identified poor alert quality as the primary driver of fatigue. The core strength of this baseline is low latency, a property SENTINEL’s Tier 1 inherits and refines.

The second group, retrieval-augmented classification agents such as CyberRAG [30], orchestrates domain-tuned classifiers behind an LLM agent, reporting over 94% per-class accuracy on web attacks. While effective at analyzing selected events, this architecture does not address front-end triage, lacking a wire-speed filtering layer to manage incoming event volume.

The third group, multi-agent and governance-focused frameworks, includes AutoBnB-RAG [31], LanG [32], and Policy-Guided Threat Hunting [33]. AutoBnB-RAG evaluates multi-agent incident response in simulated tabletop environments (*Backdoors & Breaches*). LanG utilizes LangGraph with human-in-the-loop checkpoints and dual-layer defense (regex plus Llama Prompt Guard 2 achieving 98.1% F1). Policy-Guided Threat Hunting employs reconstruction autoencoders and deep reinforcement learning prior to LLM contextual analysis.

A precise research gap emerges: cost-tiering exists in Policy-Guided Threat Hunting, prompt defense exists in LanG, and local execution is demonstrated across systems. However, no single architecture unifies: (1) resolving the vast majority of telemetry at a statistical/ML tier with sub-millisecond latency and offload rates modeled by attack base rate; (2) stateful reasoning on a local GPU under strict retrieval grounding rules; and (3) structural

prompt defense paired with HMAC-SHA256 forensic sealing. Table 1 provides a detailed comparative analysis.

Table 1. Comparative analysis between SENTINEL and existing security defense solutions

Evaluation Criteria	SIEM / SOAR (QRadar, XSOAR)	LLM Agents (CyberRAG, LanG, Policy-Guided)	SENTINEL Architecture (Thesis)
Core Technique	Static correlation rules, rigid Python/JS scripts	Agentic RAG, multi-agent orchestration, DRL pre-classification	Rule-based signatures + Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Operational Goal	Centralized log aggregation and playbook response	Automated incident investigation via language reasoning	Resolve volume at cheap tier, reserve costly tier for complex cases
Latency & Cost Tiering	Single cheap tier, no context reasoning	Present in select works (DRL pre-classification); offload rate not modeled by attack rate	Two-tier: ≤ 0.88 ms at T1; 90% – 97% offloading before T2
Data Sovereignty	On-premise local	Local deployment reported; hardware constraints not strictly bounded	100% Air-gapped on local GPU
Prompt Defense	Not applicable	Probabilistic classifiers (LanG: regex + Prompt Guard 2, 98.1% F1)	Structural Nonce guarantee, payload-wording independent
Forensic Audit	Standard text logs (susceptible to tampering)	Audit logs recorded (LanG: <code>mcp_audit.db</code>); no cryptographic sealing	HMAC-SHA256 tamper-evident evidence chain

Chapter 3

System Design and Technical Implementation

This chapter details the research methodology, followed by the system design and experimental implementation of SENTINEL: the two-tier processing pipeline, Tier 1 wire-speed filter and Machine Learning Gate, Tier 2 stateful LangGraph agent and Threat Memory, Dual-RAG hybrid knowledge retrieval, and adversarial AI security controls with cryptographic audit sealing.

3.1 Research Methodology

The thesis adopts the Design Science Research Methodology (DSRM) [41]. The core contribution of this research is a technical artefact, evaluated quantitatively through objective empirical metrics rather than purely conceptual arguments. The system is structured upon three core technical pillars:

1. *Rule-based, Statistical, and Machine Learning Pillar*: Provides wire-speed stream filtration via application signature rules (Rule-based), Welford $\mathcal{O}(1)$ online statistics [17], combined with a LightGBM Machine Learning Gate [18].
2. *Agentic Logic Pillar*: Provides deep contextual reasoning through a LangGraph state-graph [22] orchestrating a locally deployed Foundation-Sec-8B-Instruct model [20] over hybrid FAISS/BM25/RRF retrieval [24–26].
3. *Adversarial Security Pillar*: Establishes a robust defensive perimeter against log-substrate prompt injection risks [6, 8] and seals evidence records via HMAC-SHA256 signature chaining [28].

Operational efficacy of the SENTINEL architecture is quantitatively evaluated across five core measurement dimensions: classification quality, processing latency and throughput, adversarial resistance, explanation coherence (scored independently by a judge model), and forensic audit trail integrity. Comprehensive empirical results, comparative baselines, and system limitation verifications are detailed in Chapter 4.

3.2 SENTINEL Architecture Overview and SOC Stack Integration

SENTINEL operates under a cognitive two-tier architecture centered on computational cost-tiering. Raw telemetry from perimeter sensors streams into a Redis Stream queue and routes to Tier 1. Tier 1 serves as a stateless statistical and machine learning processing stage, resolving the majority of traffic volume at wire-speed. Among Tier 1’s action vocabulary, only ESCALATE proceeds to Tier 2, while BLOCK_IP, ALERT, AWAIT_HITL, and DROP terminate at Tier 1. This grounds the offload rate definition used in Chapter 4: an event is offloaded when resolved without triggering a language model invocation.

At Tier 2, the LangGraph agent [22] performs deep contextual reasoning over the Foundation-Sec-8B-Instruct model [20] (GGUF Q4_K_M quantized), integrating historical state from Threat Memory and evidence from Dual-RAG. Model outputs are bounded by a deterministic guardrail enforced to 3 action states (BLOCK_IP, LOG, AWAIT_HITL), with all records from both tiers sealed via HMAC-SHA256 signature chains [28]. SENTINEL operates as cognitive middleware between SIEM collectors and defense enforcement systems (NGFW/SOAR), absorbing stream noise at Tier 1 and providing cited justifications for escalated events at Tier 2, guaranteeing data sovereignty via air-gapped execution on a local GPU [7]. The complete processing flow and component interactions are illustrated in Figure 1.

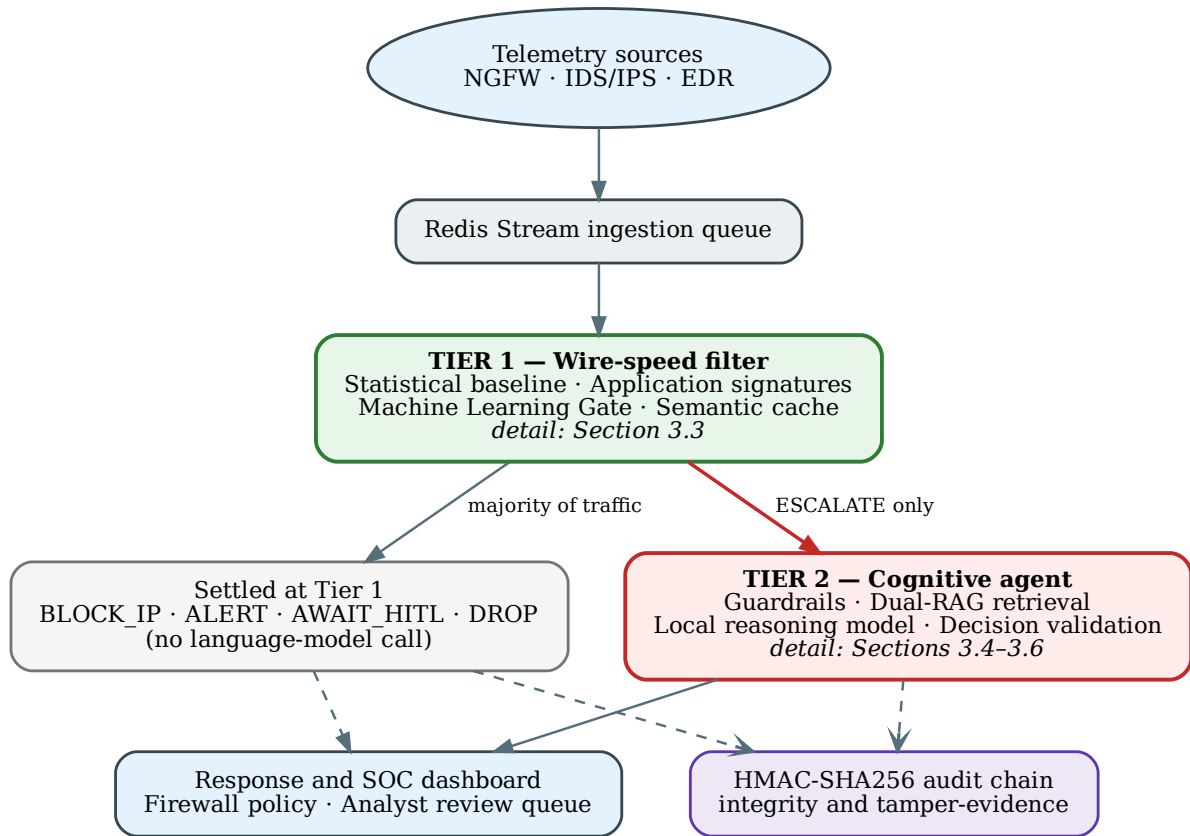


Figure 1. SENTINEL architecture overview. (Source: Author)

3.3 Tier 1: Wire-speed Filter and Machine Learning Gate

Tier 1 operates as a stateless wire-speed perimeter layer combining application-layer signature rules and a Welford $\mathcal{O}(1)$ baseline statistical filter [17] (Equation 2.1). The signature engine covers 30 attack families normalized to OWASP CRS 3.3 benchmarks [9] (23 mapping to OWASP Top 10:2021; 7 targeting network/endpoint anomalies like ransomware and cryptomining). Concurrently, the Welford filter computes streaming Z-scores $Z = (x - \mu)/\sigma$ over flow attributes (packet rate, byte count, duration), updating baseline parameters μ and σ to discard conforming telemetry automatically. Detailed Tier 1 processing flows are shown in Figure 2.

For high-volume repetitive traffic (DDoS, credential stuffing), the Tier 1.75 Semantic

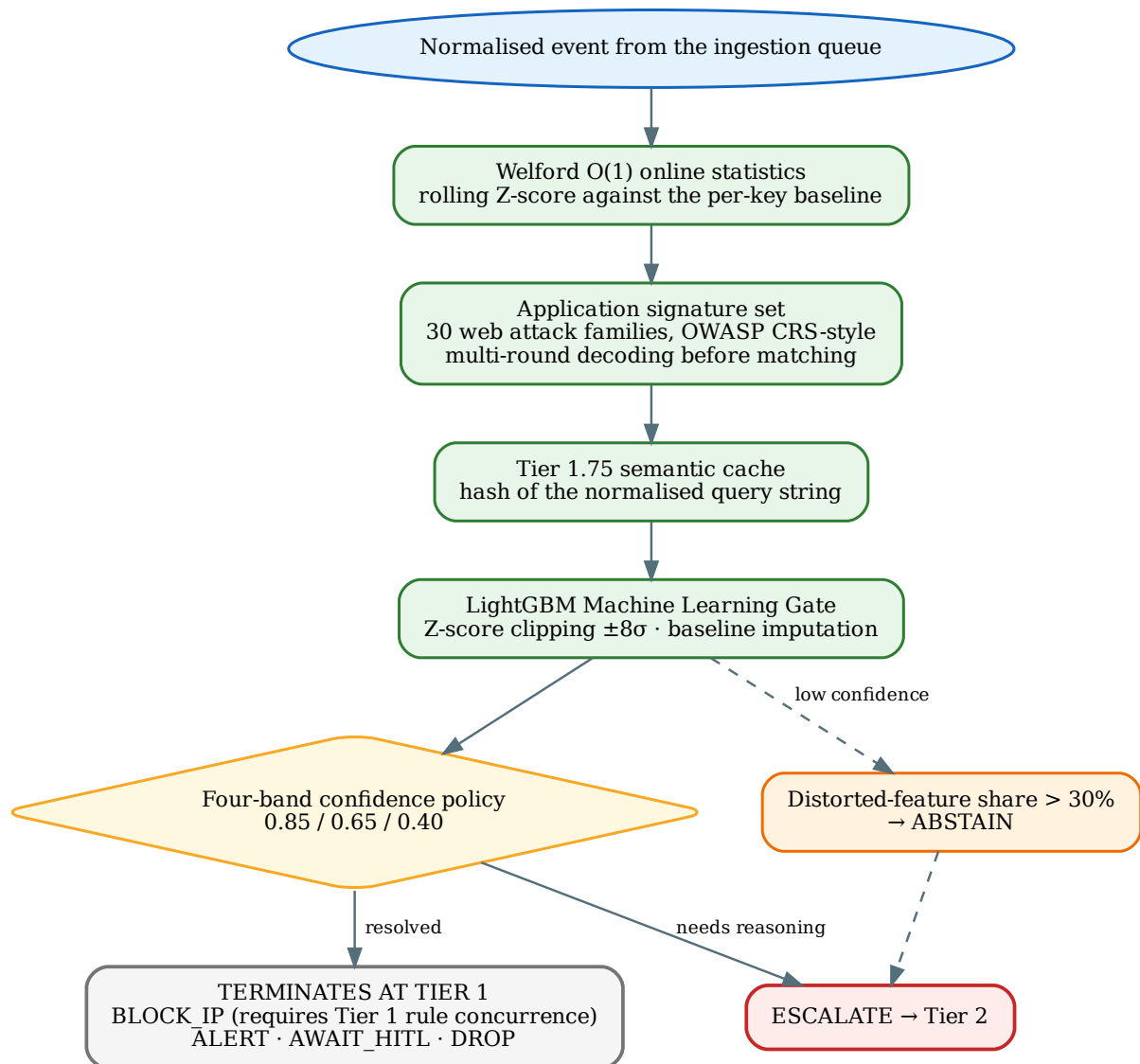


Figure 2. Tier 1 detail diagram. (Source: Author)

Cache hashes normalized query strings in RAM, reusing prior decisions in < 1 ms without recalculation overhead.

Downstream, the LightGBM Machine Learning Gate [18] evaluates non-linear feature interactions, trained on 949,535 NetFlow telemetry records from the CSE-CIC-IDS2018 benchmark [10] (664,674 training, 189,907 test). To counter evasion, the Gate clips Z-scores to $[-8, 8]\sigma$, imputes missing values with baseline means, and abstains to Tier 2 when distorted features exceed 30%. Adjudications map via a 4-band confidence policy (0.85 / 0.65 / 0.40 for BLOCK_IP / ESCALATE / ALERT / LOG), ensuring automated blocking executes only at highest confidence with signature concurrence.

3.4 Tier 2: LangGraph Cognitive Agent and Threat Memory

Tier 2 executes the Foundation-Sec-8B-Instruct model [20] (GGUF Q4_K_M) served by a CUDA-compiled llama.cpp engine on a local GPU. Reasoning flows are orchestrated by a LangGraph state-graph [22] across core stages: guardrail inspection (guardrails), context enrichment (rag_context), incident triage (llm_triage), technique mapping (attack_mapper), and action execution (action_executor) or human-in-the-loop hand-off (human_in_the_loop). The agent state-graph is illustrated in Figure 3.

At attack_mapper, absent explicit knowledge evidence, events route to analyst review (AWAIT_HITL) rather than emitting speculative actions. At llm_triage, ground-truth fields are stripped from the prompt for evaluation objectivity. Input context is managed via Drain log-template mining [34] paired with token budget monitoring.

To correlate multi-stage threat activities, Tier 2 maintains Threat Memory on SQLite (rollback-journal mode preventing Docker file locking). Reputation score S decays over silent period t : $S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t$ where λ is the decay rate. Upon reaching $S = 100$, Tier 1 enforces permanent block-on-sight without re-triggering Tier 2. Critical internal infrastructure addresses are whitelisted to eliminate self-inflicted Denial of Service (Self-DoS) risks.

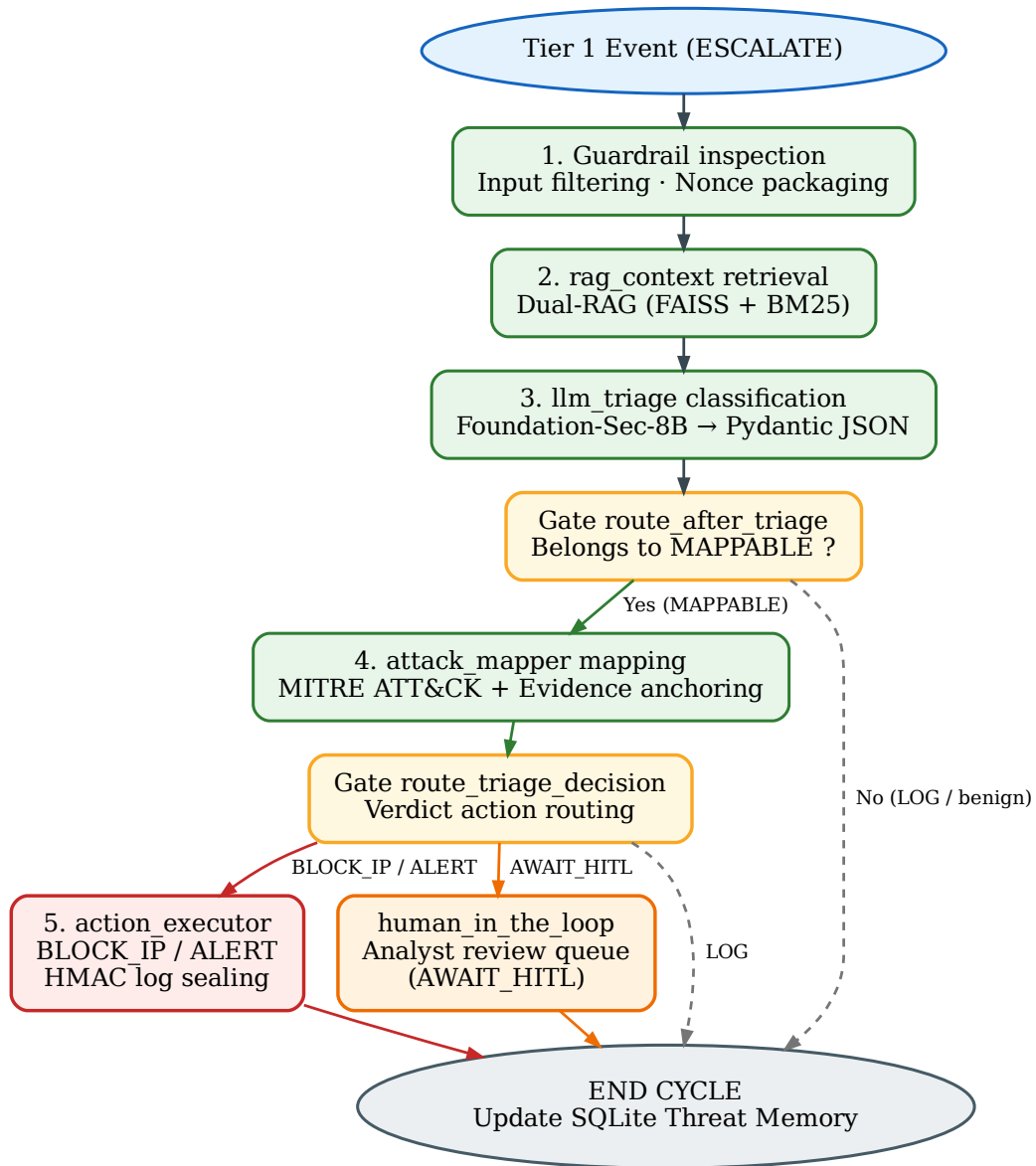


Figure 3. Tier 2 agent state-graph. (Source: Author)

3.5 Dual-RAG Hybrid Knowledge Retrieval

To eliminate hallucinations, Tier 2 retrieves over a knowledge base of 433 STIX 2.1 MITRE ATT&CK entries [35] and NIST SP 800-61r2 guidelines [36]. Parallel channels combine FAISS [24] (Sentence-BERT [37]) for dense vector intent search with BM25 [25] for sparse keyword matching of CVEs and service ports. Results are merged via Reciprocal Rank Fusion (RRF, $k = 60$) [26] and injected at `rag_context` (Figure 4).

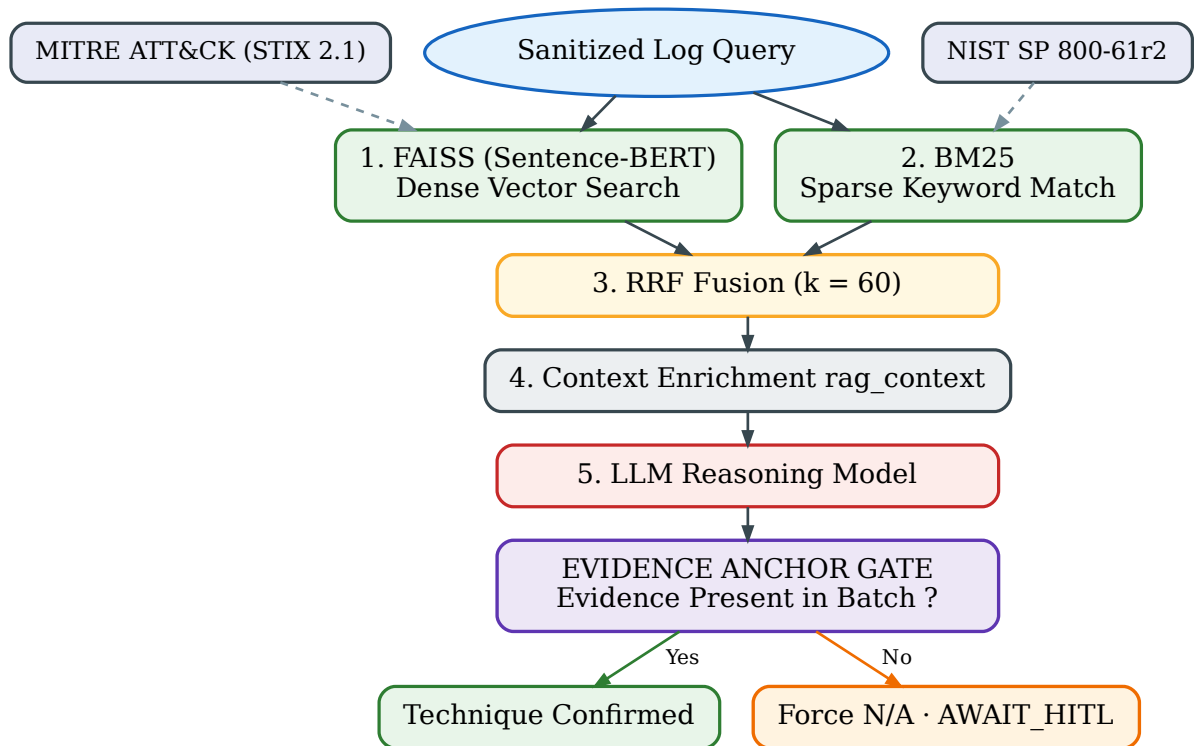


Figure 4. Dual-RAG hybrid retrieval and output evidence-anchoring guardrail. (Source: Author)

Retrieved text is sanitized by Unicode normalization, markup stripping, and command neutralization to prevent indirect injection. At output, an evidence-anchoring guardrail cross-references proposed MITRE ATT&CK codes against batch evidence. Unanchored codes are forced to N/A and deferred to AWAIT_HITL, eliminating hallucination risks.

3.6 Adversarial AI Security and Cryptographic Audit Sealing

Log prompt injection attacks [6, 8] embed control instructions inside raw log fields (User-Agent, URI). SENTINEL mitigates this via Delimited Data Encapsulation using dynamic per-batch random Nonce tokens, preventing delimiter escape (Figure 5). Three deterministic boundary validators guard system integrity: Data (filters malformed logs), Decision (enforces Pydantic LLMDecision and blocks internal IP bans), and Feedback (Zero Trust for AI rules).

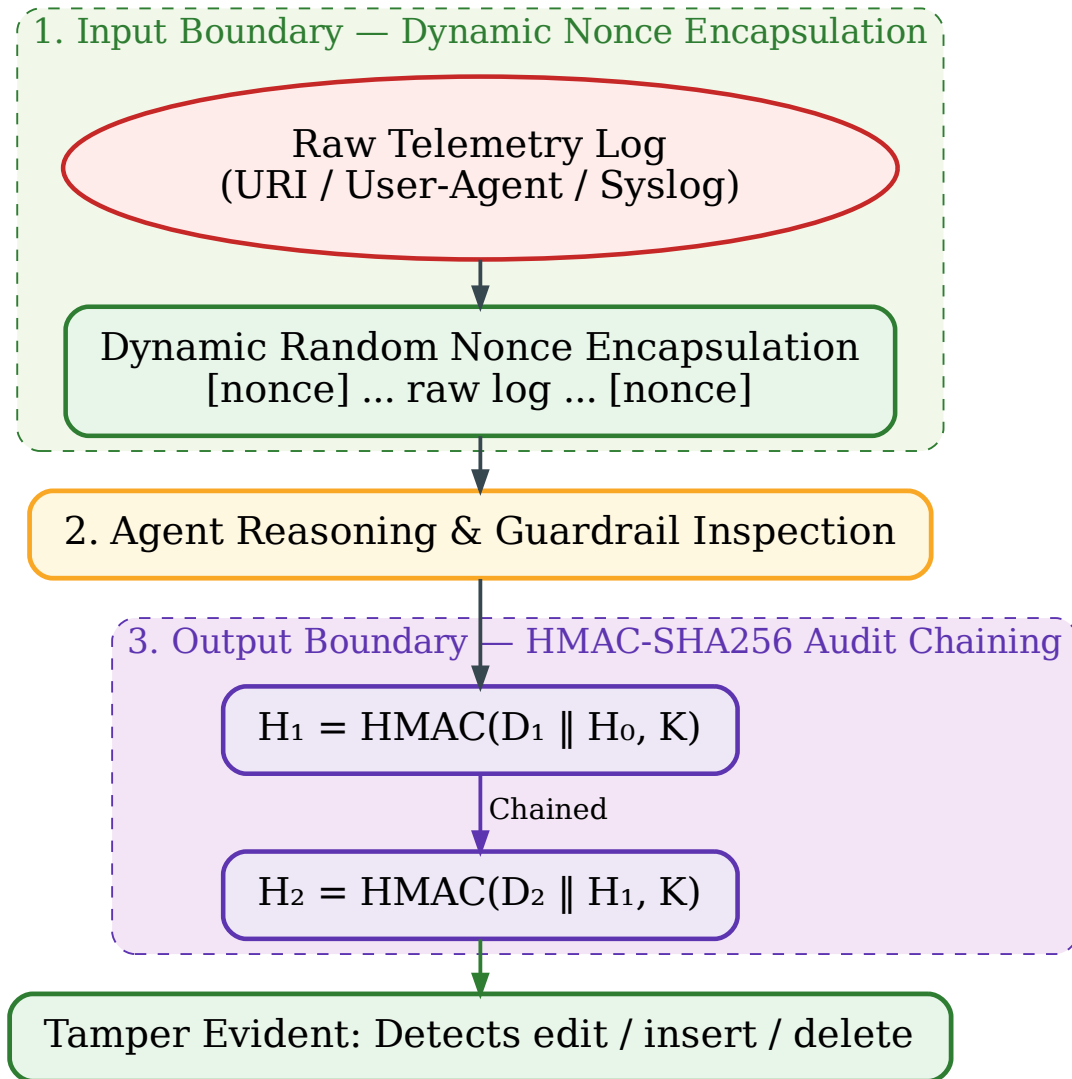


Figure 5. Input Nonce encapsulation and output HMAC audit chaining. (Source: Author)

For forensic auditing, each adjudication record D_i is cryptographically chained using HMAC-SHA256 [28]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.1)$$

where H_{i-1} is the preceding record hash and K is the local secret key. Modifying, inserting, or deleting records breaks chain continuity and is flagged instantly, ensuring tamper evidence.

Chapter 4

Experiments and Evaluation

This chapter presents the comprehensive empirical evaluation of the SENTINEL system across three core dimensions: wire-speed stream offloading performance, adversarial AI security guardrails with cryptographic audit integrity, and stateful agentic reasoning quality. Experiments were executed on an air-gapped server environment containerized via Docker Compose (Intel Core i7, 32 GB RAM, local NVIDIA GPU running CUDA 11.4.0) with Foundation-Sec-8B-Instruct [20]). Following Section 3.1, offloading performance is evaluated on live telemetry streams (25,649-event benchmark stream and 99,717-event SOC-like stream), while classification quality and security guardrails are assessed across benchmark datasets (CSE-CIC-IDS2018 [10], CSIC 2010 [11], DAPT 2020 [12]) and 823 adversarial attack samples (AdvBench [13], deepset [14], jack-hhao [15], Shen et al. [38]). Dynamic rules were frozen during evaluation, and the 50 author-composed samples in `ground_truth.json` were excluded from all ratio calculations. All metrics are reported with their respective measurement denominators to ensure empirical transparency and reproducibility.

4.1 Stream Offloading Performance and Filtration Economics

An event counts as offloaded when it generates no language model invocation (Section 3.2); counting only DROP would omit BLOCK_IP, ALERT and AWAIT_HITL, none of which spend a token.

Table 2 carries the contribution: the offload rate is a function of the stream’s attack base rate, not a constant of the system. Within a stream it decomposes linearly as $\text{offload}(p) =$

Table 2. Per-Tier Offload Rate on Two Streams with Different Base Rates

Resolving Tier	Benchmark stream, 25,649 ev		SOC-like stream, 99,717 ev	
	Events	Share	Events	Share
Tier 1 (rules + Welford + signatures)	20,663	80.6%	38,207	38.3%
Machine Learning Gate (4-band)	2,568	10.0%	58,992	59.2%
Cumulative — never reaches LLM	23,231	90.6%	97,199	97.5%
Remainder → Tier 2 (LLM)	2,418	9.4%	2,518	2.5%
<i>Attack base rate of the stream</i>		31.6%	9.8%	

$(1 - p) \cdot \text{offload}_{\text{benign}} + p \cdot \text{offload}_{\text{attack}}$. The benchmark per-label rates, 92.35% benign and 86.72% attack, reproduce the measured 90.6% exactly; on the SOC-like stream, 97.88% and 93.77% reproduce 97.5%. Because the coefficients differ between streams, the relation licenses projection to another base rate within a stream, not transfer between streams—and the 90.6% is therefore not a ceiling but the consequence of a test stream loaded with more than three times the realistic attack proportion. The tier carrying the load also inverts: Tier 1 resolves 80.6% on the benchmark stream, while the ML Gate becomes the primary carrier at 59.2% on the benign-dominated one, so the two tiers compensate rather than overlap.

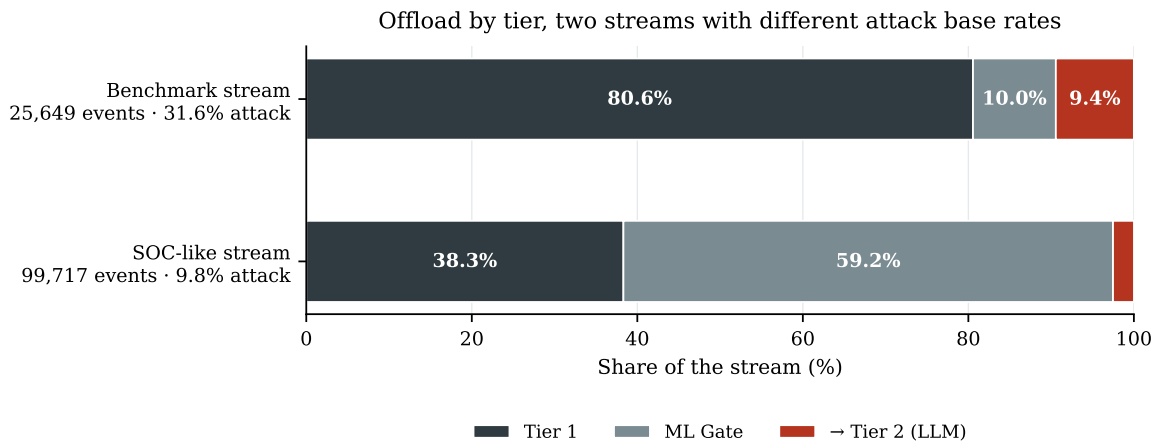


Figure 6. Offload composition on the two streams; the tier carrying the load inverts with the attack base rate. Generated from `offload_vs_baserate_{stream,demo}.json`. (Source: Author)

The ML Gate processes a feature vector in 0.287 ms (3,452 events/second) and the Tier 1.75 cache hits 81.3% of 1,500 queries at an $8.9\times$ speed-up. One quality figure belongs beside these, because a 90.6% offload rate would read the same as passing almost everything if the offloaded portion were adjudicated wrongly: on `datatest.json` the Gate

reaches MCC 0.667 and Balanced Accuracy 0.833—MCC rather than Accuracy, since answering benign everywhere already scores 90.2% Accuracy on the SOC-like stream. The denominator travels with it: of 4,236 events, the Gate adjudicates 2,534, because 1,586 lack payload features and 116 abstain. Its 962 autonomous blocks achieve 100% Precision with zero false positives, representing an essential operational prerequisite rather than merely an empirical achievement: offloading mechanisms that misclassify legitimate enterprise traffic cause service disruption rather than operational efficiency.

Harvesting 598 rules from the Gate’s blocking adjudications lowers the escalation rate from 20.28% to 17.98%, a relative reduction of 11.35%, while detection quality rises rather than falls. Two limits keep this proportionate: absolute MCC stays low ($0.071 \rightarrow 0.109$), so the mechanism is shown to operate rather than to make Tier 1 strong; and the simulation is optimistic, since the attacker never rotates source addresses and every proposed rule is approved.

On 500 events sampled strided from `build_stream()`, mean latency falls from 17,187.9 ms to 5,286.7 ms (-69.2% , Mann-Whitney U $p \approx 9 \times 10^{-57}$), and the median from 17,174.7 ms to 0.88 ms—a factor of roughly 19,500, because the typical event never reaches the model. Two results run against the system. The 95th percentile is worse, 25,829 ms against 21,434 ms, structurally so: an escalating event pays the Tier 1 and Gate cost before the model cost, so the gain sits in the median and not in the tail. And this run’s own offload rate was only 76.8%, not the 90.6% of Table 2, because 500 strided samples never accumulate enough per-address history for the blocklist to engage. Resource saving is reported as invocations avoided (97,199 of 99,717 events) rather than as a VRAM percentage, because no VRAM measurement was made.

Four controls were measured on one identical 150-event stratified subset rather than by importing headline figures from other publications, which would compare across different datasets and metric definitions.

The deterministic path runs $20,531 \times$ faster than routing every event to the model. Static signatures are faster still, about three times SENTINEL, as expected since they perform

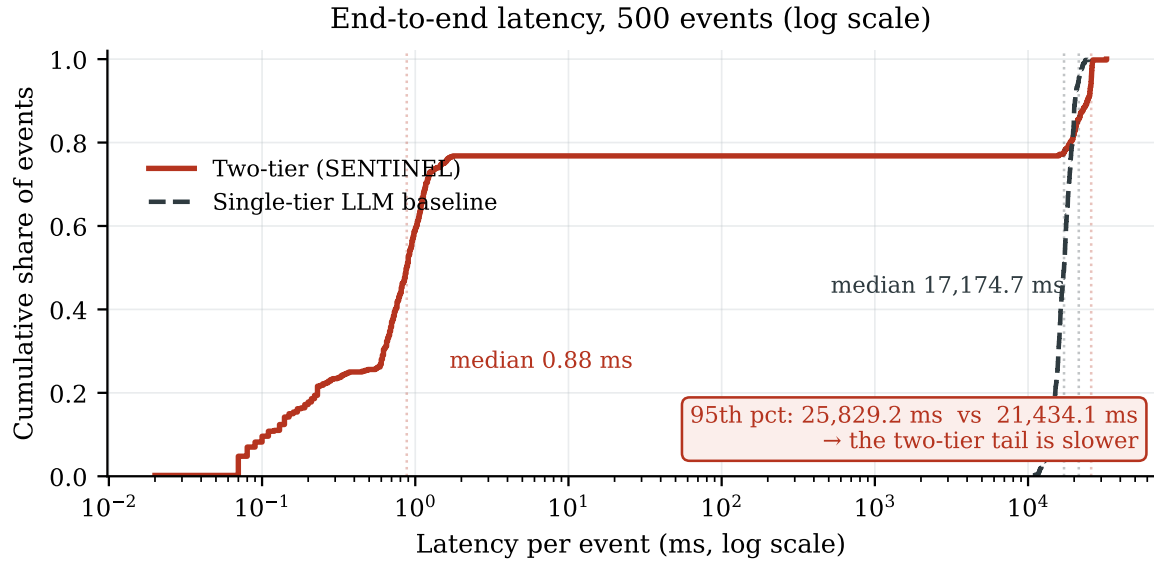


Figure 7. Cumulative latency distribution over the same 500 events. The advantage is concentrated in the body of the distribution; in the tail the two-tier system is slower. Generated from `latency_benchmark.json`. (Source: Author)

Table 3. Throughput of Control Configurations on an Identical 150-Event Stratified Subset

Control Configuration	Throughput
H1 — Static signatures, 30 WAF families	11,129 ev/s
SENTINEL — Tier 1 + ML Gate	3,860 ev/s
H2 — Single-tier LightGBM, flat threshold	2,162 ev/s
H3 — Single-tier LLM (identical data, model, and prompt)	0.19 ev/s

no inference. The ordering is the architectural argument in one line: each tier costs what it costs, and the design question is how much traffic is settled before the expensive one. Two of these figures must not be combined, since the 0.19 ev/s puts each event through the full Tier 2 agent while the 17,187.9 ms baseline is a bare model call with no token ceiling. Under surge load on the 99,717-event stream, consumer-group lag backpressure keeps RAM and VRAM stable.

The block threshold sits on a flat region—0.70 through 0.85 give identical aggregate quality and only above 0.90 does recall fall—so 0.85 buys the widest margin for autonomous blocking at no measured cost, and autonomous-block precision stays 1.00 across every configuration swept. Against synthetic anomalies injected from 2σ to 100σ over seven flow features, every probe at every magnitude was escalated, so nothing passed silently; but statistical *notice* plateaus, rising from 19.52% at 2σ to 42.86% at 4σ and reaching only 54.29% at 100σ . Beyond about four standard deviations the limit is the feature set, not the threshold, so novel behaviour reaches Tier 2 by escalation rather than by recognition—the correct failure mode, but not a detection claim.

4.2 Adversarial AI Guardrails and Cryptographic Audit Integrity

Research Question 2 (RQ2) addresses log-substrate prompt injection as a representative risk vector rather than the entire attack surface; consequently, two structurally distinct attack surfaces are evaluated: attack through language, where resistance means an embedded instruction fails to change the agent’s action, and attack through feature space, where resistance means a distorted sample is not flipped to benign. Three conventions make the ratios readable. The static verdict is the logical OR of three detectors recorded individually, so a failure can be located. A negative control over 230 benign logs is mandatory, because a layer that flags everything also achieves 100% blocking. And published-corpus and author-composed samples are never merged.

The static pre-filter blocks 18.8% of published corpora, and that must be read with the 20.0% false-flag rate on benign logs. All 46 false flags come from the encoding-detection

Table 4. Guardrail Layers, Measurement Denominators, and Results

Guardrail layer	Denominator	Result
<i>Tier 1 — attack through language</i>		
Static pre-filter, published corpora	703 samples	132 → 18.8%
by detector: pattern / encoding / delimiter	703	114 / 29 / 0
Static pre-filter, author-composed	80 samples	58 → 72.5%
Static pre-filter, cross-check set	40 samples	2 → 5.0%
Static pre-filter — false flags on benign logs	230 benign logs	46 → 20.0%
of which: encoding-detection layer	46/46	all of them
<i>Tier 1 — attack through feature space</i>		
ML Gate — evasion, hard mode (all features distorted; 13 flipped, 95% CI 97.86–99.27)	1,036 detected attacks	1,023 → 98.75%
ML Gate — single-feature modes (∞ / extreme)	$1,036 \times 2$	100% both
ML Gate — abstention on distorted input	4,236 events	116 → escalate
<i>Tier 2 — structural guarantee</i>		
Delimited nonce encapsulation	678 hard samples, coverage 100%	678 → 100%
Field-position set, by position	100 published samples	24/24, 23/23, 30/30, 23/23
Schema validation under forced backend failure	1 induced failure	AWAIT_HITL, no crash
Determinism (same seed, 5 runs) / seed-only variation	5 runs / 10 samples	identical / 0 flipped
Context-overflow guard	16,384-token window, 4,000-token budget	worst case 1,655
<i>Forensic integrity</i>		
HMAC — three core tampering modes	30 trials each	100%
HMAC — negative control (intact chain)	450 records	no false alarm
HMAC — tail truncation	—	0% — undetectable

layer, and their cost is bounded: a static flag raises the isolation level and annotates the record but does not drop the event or block the source, so it is a rate of unnecessary annotation, not of benign traffic denied service. The author-composed subset blocks at 72.5% because 45 of those 80 samples are encoding-bypass cases the neutraliser was built for; reporting the merged 23.3% rate would overstate defensive efficacy by incorporating samples designed with prior knowledge of the static rules; therefore, 18.8% is presented as the authoritative evaluation metric.

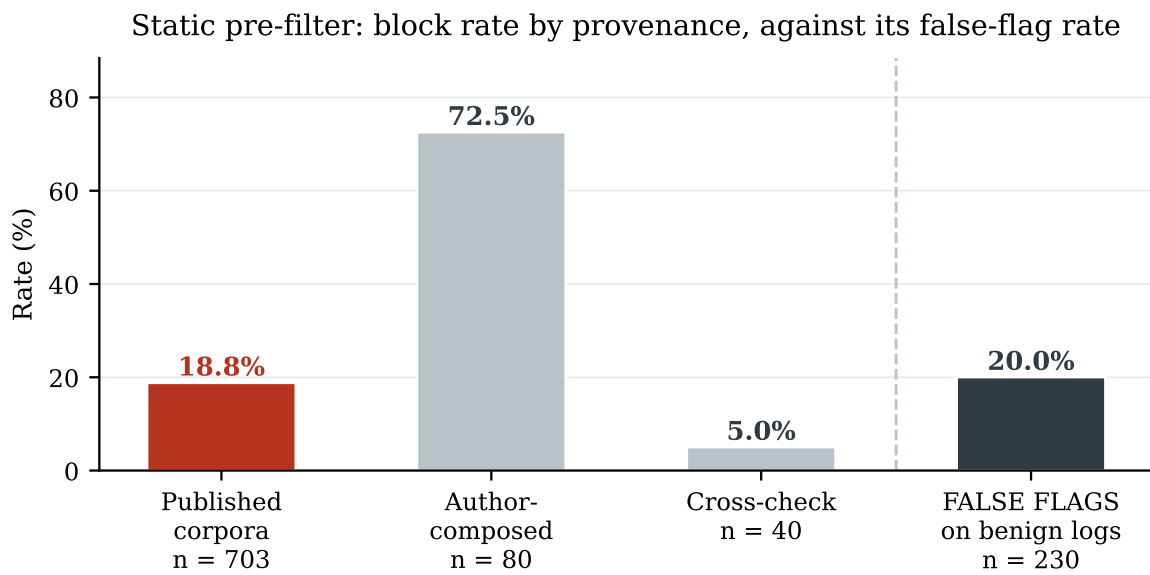


Figure 8. Static pre-filter, block rate by provenance beside the false-flag rate on benign logs. Generated from `robustness_results.json` and `adversarial_negative_results.json`. (Source: Author)

Under the hard mode, in which *every* feature of a detected attack is driven to an extreme, 98.75% of samples resist. The two single-feature modes reach 100%, and the thesis cites the hard mode rather than an average, because averaging in two trivially saturated modes would inflate the figure past what the defence demonstrated. Abstention counts as a guardrail outcome: 116 events were safely escalated to Tier 2 rather than speculatively adjudicated.

The security guarantee comes from Delimited Data Encapsulation, evaluated at 100% coverage on all 678 samples of the seven categories the static layer does not absorb—a superset of the 543 that genuinely bypassed it, so the test is stricter than required rather than favourably sampled. Tier 2 resisted 678 of 678. That is the categorical difference: a clas-

sifier blocking $x\%$ always leaks the rest and degrades against novel variants, whereas a structural guarantee does not depend on recognising malicious content at all, so the 18.8% does not contradict the thesis but quantifies the work the structural layer absorbs. Field position is tested separately, because encapsulation wraps per field and no aggregate can probe it: across 100 samples spread over URI, User-Agent, message and payload, the static layer blocked 12 while Tier 2 resisted all 100, uniformly across the four positions. Two robustness controls bound the LLM-dependent measurements, each with its limit: a fixed seed gave identical actions across five runs but on one sample, and varying only the seed over ten samples flipped nothing, which at $n = 10$ bounds the flip rate at just 0.2775 and saturates on a single action.

Verification recomputes the chain from the genesis record; because each link consumes its predecessor's hash, one altered byte in D_j invalidates every link from j onward, making detection positional rather than emitting a generic alteration notification. The three core modes—content edit, forged insertion, deleted middle record—are each detected in 30 of 30 trials, with no false alarm over 450 intact records. The measurement used a key from the environment, not the in-source default, since a key visible in source would let the chain be forged and void every rate above. Tail truncation is undetectable, an inherent property of log-chaining; the remedy is periodic anchoring of hash values outside the system.

The per-position result initially rested on 79 independent adjudications rather than 100, because the second-layer cache key omitted `user_agent` and collapsed the 23 User-Agent samples onto two fingerprints—two verdicts replayed twenty-one times, in exactly the column the experiment existed to test. A defect in the measurement apparatus and a live cache-poisoning surface were the same defect, since an attacker could equally steer a field absent from the key and be served a stored verdict. Widening the key restored 100 distinct fingerprints; the corrected result is identical to the uncorrected one, which is precisely why a denominator must be verified rather than assumed.

4.3 Agentic Cognitive Reasoning and Attack Technique Attribution

The four core dimensions evaluated under Research Question 3 (RQ3)—technique attribution, retrieval efficacy, transparent reporting, and analyst workload reduction—are measured independently to isolate distinct failure modes. Evaluating the full agentic reasoning pipeline demonstrates a trade-off in fine-grained technique attribution accuracy. On an identical population of 500 payload-layer samples (250 labelled, 250 benign, from CSIC 2010), retrieval alone attributes 80.0% exactly, while the full agent falls to 68.0%, and tactic-level from 80.0% to 70.4%, with median latency rising from 0.54 ms to 13,293 ms. The reasoning tier incurs a four-order-of-magnitude increase in processing latency while yielding lower attribution accuracy than the underlying retrieval layer. Of the 30 samples lost, up to 22 are cases where the anchoring guardrail forced N/A because the proposed technique was absent from that batch’s retrieved documents—a deliberate trade of accuracy for the guarantee that the system never acts on an unsupported identifier. Any figure here reads against a baseline floor, not zero: T1595.003 is 130 of the 250 labelled samples, so always answering it already scores 52%.

Table 5. Attribution by technique on the 500-sample payload slice, with the retrieval ceiling for the same queries. Attribution is scored on all 250 labelled samples; retrieval on the 243 of them that Tier 1 escalated, and at parent-technique granularity, so the two denominators differ and are not interchangeable.

ATT&CK technique	<i>n</i>	Retrieval hit@3	Retrieval only	Full agent
T1190 — Exploit public-facing application	52	1.00	100.0%	63.5%
T1059.007 — JavaScript execution	30	1.00	100.0%	73.3%
T1595.003 — Wordlist scanning	130	0.96	90.8%	86.9%
T1083 — File and directory discovery	12	0.00	0.0%	16.7%
T1071.001 — Web protocols	26	1.00	0.0%	0.0%
All techniques	250	0.93	80.0%	68.0%

Table 5 does what an aggregate cannot: it locates the failing tier. For T1083 the retriever never returns the correct document, so the fault is in the knowledge base and nothing downstream can recover it; for T1071.001 the retriever returns it every time and attribution is still zero, so the fault is in the mapper. The two need different repairs, and a single 68.0%

would prescribe neither.

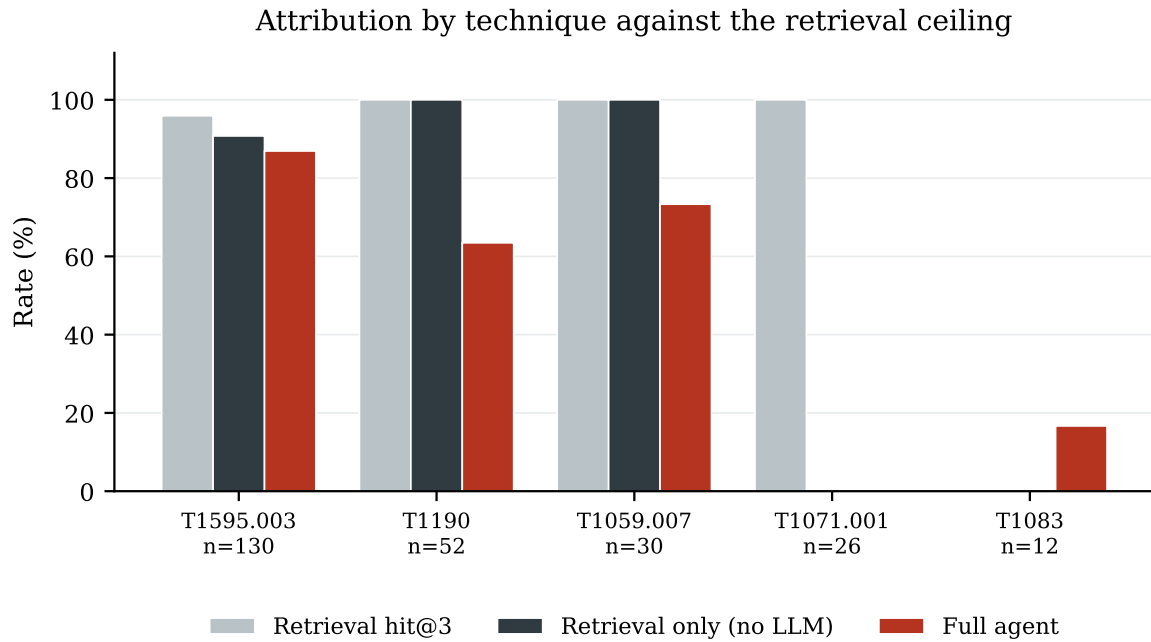


Figure 9. Attribution by technique against the retrieval ceiling. Where the light bar is high and the dark bars are zero, the mapper is at fault; where the light bar is zero, the knowledge base is. Generated from the three RQ3 result files. (Source: Author)

On the same slice of 243 escalated queries, Dual-RAG attains Recall@3 = 0.930 (95% CI 0.891–0.956) and MRR 0.803, which sits comfortably above the attribution figures and closes the argument: retrieval is not what limits the 80.0%. The unfavourable half is equally clear. Over the whole ground_truth set of 1,305 queries, Recall@3 collapses to 0.385, because flow-only samples dominate that population and carry no application-layer text to match—T1110 scores hit@3 of 0.00 across 236 queries. The two numbers describe different populations, and setting 0.385 against the 80.0% would breach the principle of empirical measurement stated in the chapter introduction.

Reading only final verdicts would score *any* shield at zero hallucinations, including one that does nothing, so the measurement runs on traces recording the action before and after the shield: of 1,566 batches, 1,421 asserted a technique, and zero of those 1,421 were unanchored—zero even when relaxed to the parent technique. The shield is not inert while achieving this: it fired on 9.26% of batches and in 76 of them downgraded BLOCK_IP to AWAIT_HITL, preventing 76 automatic permanent IP blocks whose justification could not be anchored. One limit is stated proactively: the score uses the strict criterion that the

identifier appear among retrieved document IDs, whereas the deployed shield matches by regular expression across the full context, so zero is an upper bound on leakage rather than an exact count.

Tier 1 escalated 1,066 alerts of which only 80 (7.5%) were genuine threats. When evaluated strictly as a binary classifier over this queue, the model exhibits minimal discriminative utility: it flagged all 1,066 events without filtering any of the 986 benign alerts, scoring MCC 0.0 and Balanced Accuracy 0.5, with a 99.55% false-positive rate inside the subset it actively confirmed. Its confidence is actively misleading rather than merely uninformative—mean confidence 0.846 against a true rate of 7.5%, an expected calibration error of 0.803, and the 900 highest-confidence adjudications correct zero times.

The value sits in the channel the binary framing ignores. The agent deferred 168 alerts, 15.76% of the input, and that queue holds 76 of the 80 genuine threats (95.0%) at a true-alert density of 45.24% against 7.5% at the input: a $6.03\times$ enrichment, so an analyst reviewing only the deferred queue reads 84.24% less material while still seeing 95.0% of the real threats. This empirical outcome highlights a core architectural principle: the specialized model operates effectively as a triage router rather than an autonomous decision authority. MCC 0.0 does not contradict RQ3, which asks for reduction and *accurate triage* of the work requiring a human; and since 910 of the 1,066 escalations were benign CSIC traffic, the figure also reflects Tier 1’s escalation decision, not the agent’s alone.

A cross-family judge (Meta-Llama-3-8B-Instruct scoring Foundation-Sec-8B-Instruct) graded all 1,052 escalated events on the four RAGAS axes [39], following the recommended protocol against Self-Enhancement Bias [40]: context precision 2.54, answer relevancy 4.52, faithfulness 3.96, context recall 4.11, mean 3.78/5.0. Two evaluation metrics highlight system limitations. Context precision at 2.54 represents the lowest-performing dimension and corroborates the retrieval diagnosis, since the retrieved set frequently carries entries irrelevant to the event. More seriously, evidence grounding reaches only 11.2% (95% CI 9.5–13.3): roughly nine justifications in ten quote no log value that can be checked back against the record. This is the sharpest gap between what the architecture *guarantees*

Tier 2 alert triage: the value is in the deferral channel, not the verdict

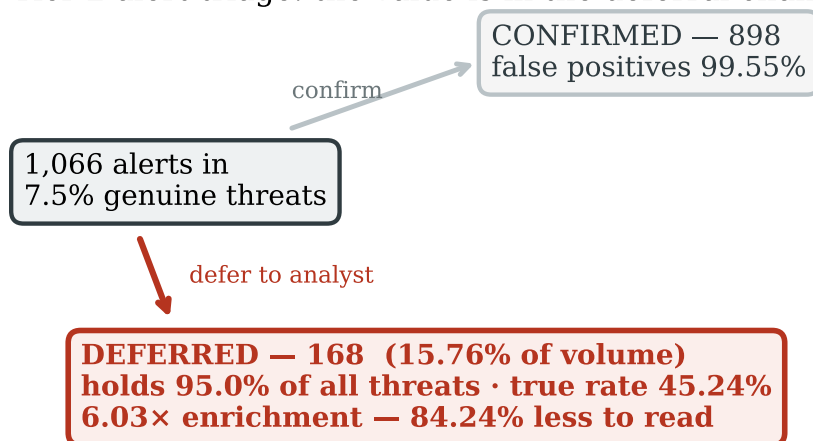


Figure 10. Alert triage at Tier 2. The confirmation channel is almost pure false positives; the deferral channel concentrates the threats. Generated from `tier2_decision_results.json`. (Source: Author)

and what it *volunteers*—anchoring can prove an asserted identifier is supported, but nothing compels the surrounding prose to cite the field values that led there—so transparent forensic reporting is only partially achieved, and closing it is a matter of constraining the justification format rather than improving the model.

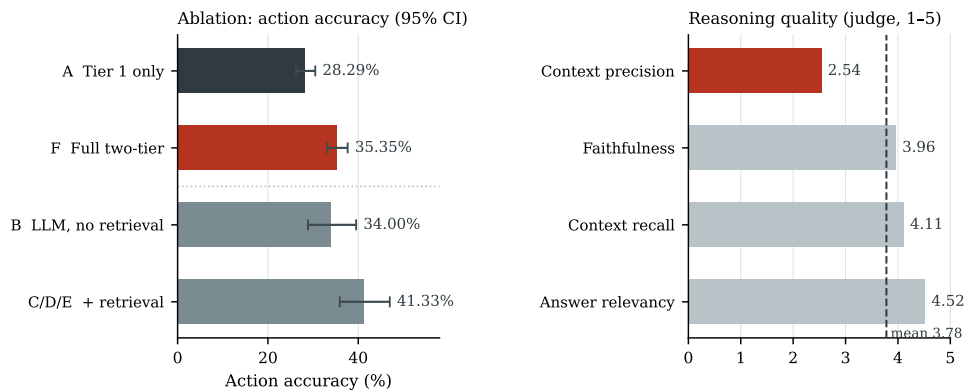
In the component ablation, the binary framing is unusable: at an 86.9% attack base rate every configuration scores close to that figure and the comparison collapses, which is why all configurations previously appeared identical. Scoring the final action instead—whether the emitted verdict matches the expected one across `BLOCK_IP`, `ALERT`, `LOG` and `AWAIT_HITL`—restores the discrimination. The change of metric is disclosed rather than passed over, because post-hoc metric selection warrants rigorous methodological scrutiny; the adoption of action accuracy is justified by the statistical degeneracy of binary classification on this imbalanced distribution.

Three key observations emerge from the empirical results. First, the agentic reasoning tier justifies its computational overhead, achieving 35.35% accuracy compared to 28.29%, with non-overlapping confidence intervals. But the trade-off inverts: Tier 1 alone is the *more* reliable adjudicator whenever it commits, 69.01% autonomous precision against 57.72%, yet it commits on only 41.00% of events and leaves 59.00% unresolved, escalating them to a tier that in configuration A does not exist. The full system leaves nothing unresolved,

Table 6. Ablation scored on the final action, with the 50 author-composed samples excluded. Configurations A and F are scored on all 1,700 remaining samples; B–E on a separate 300-sample slice and therefore not directly comparable with A and F. Generated from `ablation_action_scores.json`.

Configuration	<i>n</i>	Action acc. (95% CI)	Autonomy	Deferral	Auton. prec.
A — Tier 1 only, no LLM	1,700	28.29% (26.20–30.48)	41.00%	0.00%	69.01%
F — Full two-tier system	1,700	35.35% (33.12–37.66)	55.24%	44.76%	57.72%
B — LLM, no retrieval	300	34.00% (28.87–39.53)	69.67%	30.33%	45.93%
C — + dense retrieval	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%
D — + sparse retrieval	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%
E — + rank fusion	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%

converting that backlog into 44.76% explicit deferrals. The tiers differ less in how well they reason than in what action they execute under high uncertainty—the same property the deferral channel measured from the other direction. Third, a statistically invariant result: C, D and E are identical to numerical precision, so adding sparse retrieval to dense and fusing the rankings changes no adjudication here. That is a limitation of the ablation design rather than evidence the retrieval ladder is inert, since all three invoke the model only on escalated events and the rest of the slice falls through to the same `tier1_verdict`. Isolating rank fusion needs an evaluation restricted to escalated events, which the retrieval measurement above provides and this ablation does not.



A/F: *n*=1,700 · B–E: *n*=300, separate slice

Evidence grounding 11.2% of justifications cite a checkable log value

Figure 11. Left: action accuracy by configuration with 95% confidence intervals; A and F share a denominator, B–E do not. Right: the four judge axes, with context precision the weak one. Generated from `ablation_action_scores.json` and `reasoning_eval_results.json`. (Source: Author)

Stateful correlation reconstructed all 3 of 3 genuine multi-day DAPT2020 chains with no false campaign alert on the 4 benign sequences, but three positives put the 95% confidence interval on recall between 0.44 and 1.00, reflecting wide statistical variance compatible both with deterministic correlation and random alignment, so multi-stage correlation remains proof-of-concept. Finally, a seemingly negative result confirms the design: on the non-NetFlow group the ML Gate attains only 11.1% Recall and 305 of the full set's 336 misses fall inside it, because the Gate is trained on flow features while web attacks live in the payload—the work assigned to Tier 2 and the signature set. The aggregate Recall of 0.755 therefore aggregates heterogeneous evaluation distributions and must be reported separately. Relatedly, and as stated in Section 3.4, the escalation-to-analyst rate is not a quantity to be minimised: an architecture claiming a zero human-review rate under all conditions has discarded its final guardrail.

Chapter 5

Conclusion

A Security Operations Centre rarely fails because an intrusion went undetected. It fails at the step after detection, where a finite number of specialists must decide which of an effectively unbounded stream of alerts deserves their attention. Language models are the first technology capable of reading an event in its context and explaining it in words a person can act on, yet placing one in an operational stream imposes costs in time, trust and data sovereignty that no headline accuracy figure addresses. This thesis asked whether that capability can be obtained without paying its full price, and answered by building SENTINEL—a two-tier architecture that settles cheap decisions before expensive ones, deployed entirely on a local workstation—and then measuring it rather than describing it. Three results carry the claim.

The economics of tiering hold as a systematic principle. Tier 1 (combining application signature Rule-based rules and Welford statistical filtering) and the Machine Learning Gate resolve 90.6% of a benchmark stream carrying more than three times the realistic attack proportion, and 97.5% of a stream at a near-realistic base rate, in both cases without a single language model invocation. Because the typical event never reaches the model, median end-to-end latency falls to 0.88 ms from 17,174.7 ms under a single-tier baseline. Methodologically, the offload rate decomposes linearly into a benign-case and an attack-case rate, making it a direct function of the stream’s attack base rate rather than a static system constant.

The security guarantee is structural, and therefore does not decay. Delimited Data Encapsulation treats content inside a per-batch nonce boundary as passive text regardless of what it says, and resisted all 678 adversarial samples in the categories the inexpensive static pre-

filter cannot absorb—precisely the categories that filter is blind to. This is a different kind of assurance from a classifier that blocks $x\%$ and leaks the remainder against every novel phrasing. HMAC-SHA256 chaining detects 100% of the three core tampering modes with no false alarm over an intact control chain, sealing the forensic record with integrity and tamper-evidence.

Hallucination control became a verifiable constraint rather than a hope. Every ATT&CK identifier the system emits must appear in that batch's retrieved documents; across 1,421 adjudications asserting a technique, zero were unanchored. That zero is not the trivial score of a shield that never acts: it intervened on 9.26% of batches, and 76 of those interventions withheld a permanent IP block the system could not justify from evidence. The reasoning tier also proved most valuable in a role other than the obvious one—used as a triage router rather than an autonomous confirmer, its deferral queue concentrates 95.0% of genuine threats into 15.76% of the volume, a $6.03\times$ enrichment that removes 84.24% of the material an analyst must read.

The architecture's limits are reported in full where their evidence lives, in Chapter 4, and three set the immediate agenda: attribution is currently better without the reasoning tier than with it, the agent cannot yet dismiss a false alarm on its own, and the explanation layer is the weakest link, since retrieval admits irrelevant material and only 11.2% of justifications cite a log value that can be checked back against the record. The corresponding directions are a retrieval layer repaired at the knowledge-base level, calibration for dismissal as well as confirmation, and a justification format that compels citation rather than merely permitting it. Two smaller extensions follow from properties already stated: anchoring hash values periodically outside the system would close the tail-truncation blind spot inherent to log chaining, and asymmetric signatures would upgrade tamper-evidence to genuine non-repudiation.

Concluding a rigorous research endeavor, while opening inspiring horizons in securing the digital realm through the power of Agentic Artificial Intelligence.

References

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] B. A. AlAhmadi, L. Axon, and I. Martinovic, “99% False Positives: A Qualitative Study of SOC Analysts’ Perspectives on Security Alarms,” in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [4] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [5] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [6] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [7] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [8] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [9] OWASP Foundation, “OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks,” The OWASP Foundation, 2021. [Online]. Available: <https://owasp.org/Top10/>
- [10] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [11] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Maraón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP>
- [12] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [13] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.

- [14] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections>
- [15] jackhhao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification>
- [16] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [17] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [18] G. Ke, Q. Meng, T. Finley, T. Wang, W. Chen, W. Ma, Q. Ye, and T. Y. Liu, “LightGBM: A Highly Efficient Gradient Boosting Decision Tree,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 3146–3154, 2017.
- [19] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [20] S. Weerawardhena, P. Kassianik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), “Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report,” *arXiv preprint arXiv:2508.01059*, 2025.
- [21] P. Kassianik, B. Saglam *et al.* (Cisco Foundation AI), “Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report,” *arXiv preprint arXiv:2504.21039*, 2025.
- [22] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [23] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [24] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
- [25] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
- [26] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [27] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [28] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [29] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [30] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [31] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [32] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [33] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with

- Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [34] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
 - [35] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.
 - [36] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
 - [37] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
 - [38] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
 - [39] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
 - [40] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
 - [41] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A Design Science Research Methodology for Information Systems Research,” *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.